



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2025-67038 Lantronix EDS5000 Aviation OT Exposure Report

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-29
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2025-67038 Lantronix EDS5000 Aviation OT Exposure Report - CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-29 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review and Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape and Exploitation Status
7. Affected Products and Exposure
8. Aviation and Aerospace Sector Impact
9. Mitigation and Workarounds
10. Detection Engineering
11. Threat Hunting
12. MITRE ATT&CK Mapping
13. Validation / Lab Testing
14. Recommended Actions Summary
15. References

CVE-2025-67038 Lantronix EDS5000 Aviation OT Exposure Report

1. Executive Summary

CVE-2025-67038 affects Lantronix EDS5000 devices and is relevant to aviation environments that use serial device servers, facility systems, lab networks, or industrial edge connectivity. Lost Boys Cyber prioritizes this issue because CISA KEV records active exploitation and the affected technology commonly sits in enterprise or operational-adjacent environments. The immediate defender outcome is rapid asset identification, vendor-guided remediation, logging review, and short-cycle hunting for exploitation attempts.

Signal	Analyst Assessment
Priority	Aviation/aerospace sector threat
Exploitation status	Listed by CISA KEV as known exploited
Confidence	Medium-high based on CISA, vendor, and NVD-style references
Primary risk	Root command execution on serial/industrial device infrastructure
Recommended SLA	Internet-exposed assets: 24-72 hours; internal high-value systems: risk-based emergency change

2. Vulnerability Metadata

Field	Value
CVE	CVE-2025-67038
Vendor / Product	Lantronix EDS5000
Weakness	OS command/code injection (CWE-78, CWE-94)
CISA KEV date	2026-06-23
KEV due date	2026-06-26
Known ransomware use	Unknown in CISA KEV at collection time
Report date	2026-06-29

3. Source Review and Confidence

Source	Why it matters	Confidence
[1] CISA KEV: CVE-2025-67038	Authoritative active-exploitation listing.	High
[2] Lantronix EDS5000 firmware page	Vendor firmware and remediation source.	High
[3] NVD: CVE-2025-67038	Canonical CVE reference.	Medium

The source window favored the last 24-72 hours. Where vendor or NVD pages provide canonical vulnerability details but not a dated news article, they are used as stable corroborating references.

4. Vulnerability Details

CISA describes a username-parameter command injection issue where injected commands execute with root privileges. Aviation defenders should look beyond corporate IT and include terminal systems, facilities, labs, ground-support networks, and maintenance environments.

5. Attack Scenarios

Scenario	Preconditions	Defender concern
Internet-exposed exploitation	Affected service reachable from untrusted networks	Rapid compromise before normal patch windows
Authenticated or adjacent pivot	Attacker already has foothold, VPN, partner, or internal network access	Privilege expansion and persistence within sensitive infrastructure
Third-party managed exposure	MSP, integrator, hosted service, or vendor-managed appliance controls the affected layer	Delayed patch visibility and unclear evidence ownership

6. Threat Landscape and Exploitation Status

CISA KEV inclusion is the strongest public signal available in this collection. It confirms known exploitation, but this report does not attribute the exploitation to a named actor unless a cited source does so. Defenders should assume opportunistic scanning can follow public KEV updates and vendor disclosure timelines.

7. Affected Products and Exposure

Exposure Question	Triage Guidance
Is the affected product present?	Query CMDB, EDR software inventory, internet exposure management, and network management records for product names and vendor strings.
Is it reachable externally?	Check edge NAT, reverse proxy, VPN partner networks, SaaS administration portals, and third-party managed networks.
Are logs retained?	Preserve application, web, identity, network, and EDR telemetry for at least 30 days around disclosure and KEV addition.
Are compensating controls active?	Validate WAF, segmentation, allow-lists, admin MFA, and management-plane restrictions rather than assuming they exist.

8. Aviation and Aerospace Sector Impact

Field	Assessment
Affected segment	Airport facilities, aviation labs, MRO environments, and OT/ICS-adjacent serial connectivity.
Operational relevance	Serial device servers can bridge legacy operational devices into IP networks.
Likely exposure paths	Management interfaces, flat facilities networks, remote vendor access, and legacy serial-to-IP gateways.
Supply-chain considerations	Integrators and facilities vendors may own device configuration

	and firmware lifecycle.
Defender actions	Inventory EDS5000 devices, update firmware, segment management access, preserve auth/admin logs, and validate vendor-owned devices.

9. Mitigation and Workarounds

1. Apply vendor remediation or supported mitigation immediately.
2. Remove internet exposure for affected management/admin surfaces wherever possible.
3. Rotate secrets if exploitation is suspected or if logs show suspicious administrative actions.
4. Preserve forensic evidence before disruptive rebuilds.
5. Validate that remediation covers HA peers, templates, backup instances, and test environments.

10. Detection Engineering

Detection	Data Source	Purpose
Public-report term hunt	EDR process and network telemetry	Rapidly surface exploitation strings, validation activity, or operator notes that mention the CVE/product.
Management-plane anomaly	Authentication, web, and admin logs	Identify unusual administrator actions, unexpected file writes, or configuration changes.
Post-exploitation pivot	EDR and network flows	Detect shell, script, webshell, service creation, credential access, or outbound staging.

```
// Microsoft Defender XDR hunt - CVE-2025-67038 Lantronix EDS5000 Aviation OT Exposure Report
DeviceProcessEvents
| where Timestamp > ago(14d)
| where InitiatingProcessCommandLine has "CVE-2025-67038" or InitiatingProcessCommandLine has
"Lantronix" or InitiatingProcessCommandLine has "exploit" or InitiatingProcessCommandLine has
"webshell"
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine, InitiatingProcessFileName,
InitiatingProcessCommandLine
| union (DeviceNetworkEvents
| where Timestamp > ago(14d)
| where RemoteUrl has_any ('CVE-2025-67038', 'Lantronix', 'exploit', 'webshell', 'file write') or
DeviceEvents has "CVE-2025-67038"
| project Timestamp, DeviceName, AccountName=InitiatingProcessAccountName,
FileName=InitiatingProcessFileName, ProcessCommandLine=InitiatingProcessCommandLine,
InitiatingProcessFileName, InitiatingProcessCommandLine)
```

```
title: CVE-2025-67038 Lantronix EDS5000 Aviation OT Exposure Report Public Reporting Follow-up
id: cve-2025-67038-lantr-daily-20260629
status: experimental
description: Flags triage strings and exploit/theme terms associated with this daily Lost Boys Cyber
report.
logsource:
  product: windows
  category: process_creation
detection:
  selection:
    CommandLine|contains:
      - CVE-2025-67038
      - Lantronix
      - exploit
```

```

- webshell
- file write
condition: selection
falsepositives:
- Administrative validation and vulnerability scanning
level: medium

```

11. Threat Hunting

Hypothesis	Query / Evidence	Expected Follow-up
Exploit validation occurred before patching	Search proxy/WAF/application logs for CVE, product, exploit, and abnormal endpoint paths.	Preserve raw logs and map source IPs to scanner, vendor, or unknown infrastructure.
Successful exploitation led to execution	Hunt for new child processes, file writes, scheduled tasks, web shells, or root/admin escalation from the affected service context.	Isolate affected system and collect volatile evidence.
Third-party exposure bypassed internal visibility	Compare vendor-managed assets and network diagrams against local telemetry coverage.	Request third-party patch/evidence attestation.
<pre> index=* earliest=-14d ("CVE-2025-67038" OR "Lantronix" OR "exploit" OR "webshell" OR "file write") stats count min(_time) as first_seen max(_time) as last_seen by host user process parent_process command_line convert ctime(first_seen) ctime(last_seen) </pre>		

12. MITRE ATT&CK Mapping

Technique	Rationale
T1190 Exploit Public-Facing Application	Used when the vulnerable service is reachable from external networks.
T1068 Exploitation for Privilege Escalation	Applies where exploit impact enables privilege gain or root-level follow-on actions.
T1059 Command and Scripting Interpreter	Relevant when command injection or post-exploitation scripting occurs.
T1105 Ingress Tool Transfer	Common follow-on after initial compromise.

13. Validation / Lab Testing

No exploit code was executed by Lost Boys Cyber for this daily automation report. Validation should be limited to safe version checks, configuration review, authenticated administrative verification, and vendor-supported test procedures.

14. Recommended Actions Summary

Timeframe	Action	Owner
0-24 hours	Identify affected assets and remove unnecessary exposure.	Vulnerability management / network
24-72 hours	Patch or apply vendor mitigation; preserve logs for exposed assets.	System owner

3-7 days	Complete threat hunt and third-party attestation.	SOC / GRC
7-14 days	Review segmentation and management-plane access controls.	Security architecture

15. References

- [1] CISA KEV: CVE-2025-67038 - https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json
- [2] Lantronix EDS5000 firmware page - <https://ltrxdev.atlassian.net/wiki/spaces/LTRXTS/pages/2538438657/Latest+Firmware+for+the+EDS5000+series+EDS5008+EDS5016+EDS5032>
- [3] NVD: CVE-2025-67038 - <https://nvd.nist.gov/vuln/detail/CVE-2025-67038>